Taller de exploracion del CMS Ghost

Version solicitada: 5.130.2 | Entregable: funcionalidades, dominio y defectos

EQUIPO	NOMBRE(S)	CURSO / GRUPO	FECHA
Completar	Completar por el equipo	Completar	30 de octubre de 2026

Alcance y criterio de evidencia

Este documento sigue las tres actividades de la guia: reconocer funciones del CMS, representar el dominio y registrar diez defectos. Las imagenes no incluyen las plantillas mencionadas, por lo que se usa un formato equivalente con campos de identificacion, descripcion, pasos/condicion, resultado esperado, resultado reportado, severidad y evidencia.

INSTANCIA LOCAL: Docker Desktop 4.97.0, Docker Engine 29.9.2 y Compose v5.6.1 quedaron instalados. El contenedor my-ghost (ghost:5.130.2) inicio correctamente; el sitio responde en http://localhost:2368 y /ghost muestra la configuracion inicial. No se creo una cuenta administradora porque exige que el equipo defina sus propias credenciales. Por ello, la tabla de funciones se apoya en documentacion oficial y los defectos conservan el nivel de confirmacion indicado; los casos de seguridad de los avisos oficiales incluyen 5.130.2. Agregar capturas propias y enlaces publicos del grupo antes de entregar si el docente los exige.

Configuracion de referencia mostrada en las capturas

Ghost 5.130.2 en contenedor `ghost:5.130.2`, puerto `2368:2368`, `NODE_ENV=development`, URL `http://localhost:2368` y volumen `./ghost-data:/var/lib/ghost/content`. Rutas indicadas: sitio `http://localhost:2368` y administracion `http://localhost:2368/ghost`. La guia usa `docker compose up -d`, `docker ps` y persistencia de contenido.

La version 5.130.2 se publico el 21 de julio de 2025. La release solo menciona la prevencion de ataques homograficos con dominios punycode durante el inicio de sesion de miembros. Ghost publico despues el parche 5.130.6 para varias vulnerabilidades que incluyen el rango 5.130.2; esto se registra como hallazgo de seguridad, no como prueba visual del ejercicio.

1. Funcionalidades reconocidas

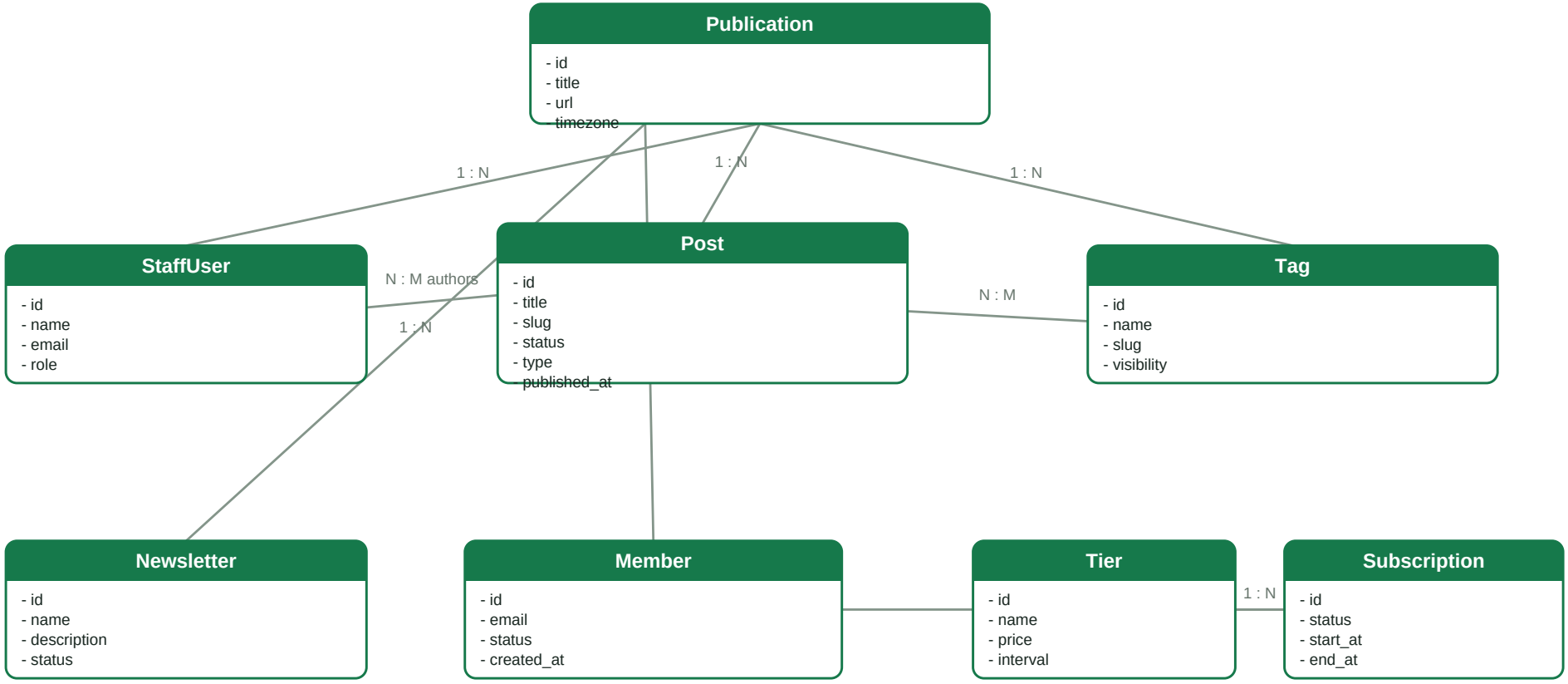
Tabla diligenciada a partir de la guia oficial de Ghost y el modelo funcional descrito para el CMS. Las acciones concretas pueden cambiar segun roles, tema, integraciones y ajustes de la publicacion.

ID	Funcion	Pasos para identificarla	Resultado / proposito
F01	Panel de administracion	Inicio de sesion del equipo; panel lateral para Posts, Pages, Tags, Members, Analytics y Settings.	Centraliza la gestion editorial y de audiencia.
F02	Crear y editar posts	Posts > New post; escribir titulo y contenido en el editor visual.	Guarda un articulo como borrador, con slug y contenido.
F03	Crear paginas	Pages > New page; redactar contenido estatico y publicarlo.	La pagina obtiene URL; no entra automaticamente a colecciones de posts.
F04	Editor con tarjetas	Insertar bloques de texto, imagen, galeria, HTML, bookmark, Markdown o separador.	Compone contenido multimedia sin editar plantillas.
F05	Borradores e historial	Editar un post no publicado; recuperar una version previa desde el historial del editor.	Permite guardar progreso y restaurar cambios previos.
F06	Vista previa	Abrir Preview y revisar escritorio, movil, email y variantes de acceso.	Genera una vista compartible antes de publicar.
F07	Publicar o programar	Publicar de inmediato o fijar fecha futura; seleccionar web, newsletter o ambos.	Cambia estado y fecha; una tarea programada se publica segun zona horaria.
F08	Acceso por audiencia	Configurar Public, Members only, Paid members o tiers en ajustes del post.	Aplica reglas de acceso y CTA apropiados en el sitio.
F09	Etiquetas	Asignar varias tags; ordenar la principal; editar metadatos de cada tag.	Organiza colecciones publicas y permite tags internos con #.
F10	Autores	Asignar uno o varios staff users como autores del post.	Muestra autoria y asocia el contenido a perfiles de equipo.
F11	Gestion de miembros	Buscar, consultar, editar, importar/exportar miembros y revisar estado/origen.	Administra la audiencia registrada y su estado.
F12	Tiers y suscripciones	Crear tiers de pago y conectar Stripe para membresias de pago.	Relaciona miembros, nivel de acceso y suscripcion.
F13	Newsletters	Configurar una o mas newsletters, diseno, remitente y destinatarios; enviar prueba.	Entrega posts por correo a segmentos de audiencia.
F14	Equipo y roles	Invitar staff como Contributor, Author, Editor o Administrator.	Limita acciones de contenido y configuracion segun rol.
F15	Diseno, navegacion y analitica	Elegir tema, editar navegacion, SEO y redirects; revisar datos de posts y miembros.	Personaliza el sitio y consulta rendimiento editorial.

Fuentes de funciones: Posts y ajustes | Pages | Publishing | Tags | Staff roles | Newsletters

2. Diagrama de dominio

Diagrama de clases limitado a atributos y relaciones. Post representa contenido editorial; Page se identifica en el atributo type. Las multiplicidades son un modelo conceptual para esta actividad, no un volcado de esquema de base de datos.



Modelo conceptual para el taller; los nombres de campos pueden variar segun la version y configuracion.

Relaciones incluidas: una publicacion contiene posts, staff, tags, newsletters y miembros; posts pueden tener varios autores y tags; un miembro puede tener suscripciones y cada suscripcion corresponde a un tier. Los posts y pages usan campos comunes de contenido, con tipo distinto.

3. Diez defectos reportados

Registro con estructura de defecto. Severidad y estado se toman del aviso/reporte cuando la fuente los define. Los reportes de seguridad describen comportamiento y alcance; por seguridad, no se incluyen cargas de explotacion. Para el taller, usar una instancia aislada y datos ficticios.

Lectura de estado: CONFIRMADO POR AVISO = rango publicado por Ghost incluye v5.130.2; FIX POSTERIOR = la release menciona un fix, pero no declara el rango afectado; REPORTE A VALIDAR = reporte comunitario o de GitHub, sin captura de esta instancia. No presentar estos enlaces como observaciones propias.

ID / modulo	Defecto y pasos/condicion	Esperado	Resultado reportado	Severidad / estado	Evidencia publica
D01 Autenticacion staff	**Omisión de segundo factor por correo** **Prueba:** Con una cuenta staff en un entorno de prueba, habilitar el segundo factor por email e iniciar una autenticacion que requiera el desafio.	La sesion queda bloqueada hasta validar el segundo factor.	El aviso oficial informa que un staff podia saltar el 2FA por email. Afecta 5.105.0-5.130.5; parche 5.130.6.	**Alta (8.1)** Confirmado por aviso; version incluye 5.130.2.	GHSA-5fp7
D02 Autorizacion API	**Permisos excesivos con Staff Token** **Prueba:** En staging, emitir token de staff de rol admin/owner y comparar acceso token vs sesion a endpoints exclusivos de sesion.	El token solo permite acciones previstas para su alcance.	El aviso describe acceso con Staff Token a endpoints que debian requerir Staff Session. Rango 5.121.0-5.130.5; parche 5.130.6.	**Alta (8.1)** Confirmado por aviso; version incluye 5.130.2.	GHSA-9xg7
D03 Admin API / Members	**Inyeccion SQL en actividad de miembros** **Prueba:** En staging, consultar el feed de eventos de miembros con filtros que contengan caracteres de consulta; no probar en un sitio real.	Los filtros se tratan como datos y la consulta no puede alterar SQL.	El aviso confirma ejecucion de SQL arbitrario mediante /ghost/api/admin/members/events por actor con credenciales Admin API. Rango 5.90.0-5.130.5; parche 5.130.6.	**Moderada (6.7)** Confirmado por aviso; version incluye 5.130.2.	GHSA-qjrp
D04 Editor / media	**SSRF en media inliner externo** **Prueba:** En staging aislado, evaluar la funcion de incrustacion de media externa usando solo un endpoint de prueba controlado por el equipo.	Ghost bloquea destinos internos y solo recupera recursos externos permitidos.	El aviso describe exfiltracion desde sistemas internos por SSRF con token Admin API. Rango publicado 5.105.0-5.130.5; parche 5.130.6.	**Moderada (5.1)** Confirmado por aviso; version incluye 5.130.2.	GHSA-vmc4
D05 Analitica de newsletter	**SQL injection en consulta de click events** **Prueba:** En staging, verificar las consultas de eventos de clicks con datos de prueba y entradas de filtro no confiables.	El endpoint valida y parametriza la consulta; no ejecuta instrucciones SQL derivadas de filtros.	Ghost registra en v5.130.6 un fix de SQL injection en la consulta de click events; el rango inicial afectado no aparece en las notas de release.	**Seguridad** Fix posterior; verificar alcance exacto de 5.130.2.	Release 5.130.6
D06 Autorizacion staff	**Bypass de permisos con token y slash final** **Prueba:** En staging, comparar requests de staff token a rutas protegidas con y sin slash final; usar endpoints benignos y permisos minimos.	La normalizacion de la ruta no debe conceder permisos extra.	Ghost incluye en v5.130.6 un fix para bypass de autorizacion de Staff Token por diferencia con slash final; rango no especificado en la release.	**Seguridad** Fix posterior; verificar alcance exacto de 5.130.2.	Release 5.130.6

ID / modulo	Defecto y pasos/condicion	Esperado	Resultado reportado	Severidad / estado	Evidencia publica
D07 Bookmarks / oEmbed	**SSRF en endpoint oEmbed** **Prueba:** Con un endpoint controlado en staging, probar el fetch de oEmbed y revisar que destinos privados no sean consultados.	La recuperacion de oEmbed rechaza direcciones internas o no permitidas.	La release 5.130.5 anuncia un fix de SSRF via endpoint oEmbed; no publica el rango exacto afectado.	**Seguridad** Fix posterior; verificar alcance exacto de 5.130.2.	Release 5.130.5
D08 Rutas / preview	**Preview publicado no redirige a URL canonica** **Prueba:** Crear un post, generar URL de preview, publicarlo y abrir la URL de preview guardada.	La URL de preview de contenido ya publicado redirige a la URL publica del post.	La release 5.130.4 anuncia un fix para la ruta preview de post publicado que no ejecutaba el redirect esperado.	**Funcional** Fix posterior; verificar en 5.130.2.	Release 5.130.4
D09 Configuracion / rutas	**Ruta Admin combina admin.url con subdirectorio publico** **Prueba:** Configurar url publica con subdirectorio, admin.url en hostname separado y revisar /ghost en el hostname Admin.	La consola Admin abre en la raiz del host Admin, segun la configuracion declarada.	Un reporte con Ghost 5.130.2 describe que el subdirectorio de url se agrega a admin.url y /ghost responde 404; issue cerrado como not planned, por tanto tratar como reporte no confirmado.	**Media** Reporte exacto para 5.130.2; cerrado no planificado.	Issue #24729
D10 Members / JWT	**JWKS publica clave RSA corta para validar JWT de miembro** **Prueba:** Obtener el JWKS publico y validar un JWT de miembro con una biblioteca que exija RS512 y RSA >=2048 bits.	La clave publicada permite validar el token segun los requisitos RS512.	El reporte para Ghost 5.x y 6.x muestra error de longitud minima de clave y registra una correccion posterior en septiembre de 2025.	**Compatibilidad** Reporte Ghost 5.x; verificar el build 5.130.2 instalado.	Issue #24831

Interpretacion para entregar

La tabla cubre diez defectos/reports publicos. Solo D01-D04 declaran explicitamente un rango afectado que contiene Ghost 5.130.2. D05-D08 son fixes publicados en versiones posteriores sin rango completo en la nota citada. D09-D10 son reportes abiertos/publicos cuya reproduccion y vigencia deben comprobarse. Antes de afirmar que el equipo encontro los diez, instalen la version indicada, sigan los pasos en un entorno aislado, anoten navegador/OS y adjunten capturas con datos ficticios.

Evidencias y bibliografia publica

Todos los enlaces siguientes son a paginas publicas del proyecto Ghost o su centro de ayuda. Abren sin compartir credenciales. Las paginas de GitHub documentan reportes de terceros y avisos del mantenedor; las capturas de la instancia local del grupo aun deben agregarse en una ubicacion publica y pegarse en la entrega del curso.

Referencia	Uso en el informe	URL publica
Guia de instalacion mostrada	Capturas proporcionadas por el estudiante; Docker Compose, Ghost 5.130.2, puerto 2368 y persistencia local.	Capturas originales adjuntas por el estudiante
Release Ghost 5.130.2	Fecha de publicacion y cambio de seguridad de dominios punycode.	https://github.com/TryGhost/Ghost/releases/tag/v5.130.2
Release Ghost 5.130.4	Fix de redireccion de preview de post publicado.	https://github.com/TryGhost/Ghost/releases/tag/v5.130.4
Release Ghost 5.130.5	Fix de SSRF via oEmbed.	https://github.com/TryGhost/Ghost/releases/tag/v5.130.5
Release Ghost 5.130.6	Fixes de seguridad: Staff Token, SSRF media, SQL click events y 2FA.	https://github.com/TryGhost/Ghost/releases/tag/v5.130.6
GHSA-5fp7-g646-ccf4	Bypass de 2FA de staff; CVE-2026-22594.	https://github.com/TryGhost/Ghost/security/advisories/GHSA-5fp7-g646-ccf4
GHSA-9xg7-mwmp-xmjx	Staff Token permission bypass; CVE-2026-22595.	https://github.com/TryGhost/Ghost/security/advisories/GHSA-9xg7-mwmp-xmjx
GHSA-gjrp-xgmh-x9qq	SQL injection en actividad de miembros; CVE-2026-22596.	https://github.com/TryGhost/Ghost/security/advisories/GHSA-gjrp-xgmh-x9qq
GHSA-vmc4-9828-r48r	SSRF por media inliner; CVE-2026-22597.	https://github.com/TryGhost/Ghost/security/advisories/GHSA-vmc4-9828-r48r
Issue Ghost #24729	Reporte con Ghost Version 5.130.2 sobre URL de Admin y subdirectorio.	https://github.com/TryGhost/Ghost/issues/24729
Issue Ghost #24831	JWKS / RS512 en Ghost 5.x y 6.x; fix enlazado en el historial del issue.	https://github.com/TryGhost/Ghost/issues/24831
Posts settings	Campos y controles de posts.	https://ghost.org/help/post-settings/
Publishing	Vista previa, publicacion, programacion y newsletter.	https://ghost.org/help/publishing-content/
Pages	Comportamiento de paginas estaticas.	https://ghost.org/help/pages/
Tags	Etiquetas, colecciones e internal tags.	https://ghost.org/help/tags/
Staff users	Roles de equipo y permisos.	https://ghost.org/help/managing-staff-user-profiles/
Newsletters	Configuracion y multiples newsletters.	https://ghost.org/help/setup-email-newsletters/